MÒDUL 06 · SEGURETAT INFORMÀTICA — RA4 · NF5-AA3

Signatura digital

Del hash xifrat a la confiança: com sabem que un document és autèntic

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



Signatura digital vs. electrònica

La tecnologia (criptografia) i el concepte legal (validesa jurídica): dues coses que sovint es confonen.



Certificats i CA

Com es resol el problema de confiar en una clau pública que no coneixem prèviament.



eIDAS: tres nivells legals

Signatura simple, avançada i qualificada: diferent validesa jurídica per a cada ús.

HO SABIES?

Signatura digital ≠ signatura electrònica

Signatura digital

És el mecanisme TÈCNIC i criptogràfic que s'utilitza per xifrar i protegir les dades d'un document. Es basa en criptografia asimètrica i funcions hash (que vau estudiar al RA3).

Signatura electrònica

És el concepte LEGAL i jurídic que atorga validesa a la voluntat d'una persona de signar un document en format digital. Es pot implementar amb diferents mecanismes tècnics: un PIN, un check, o la pròpia signatura digital.

EL PROCÉS TÈCNIC

Com es genera i verifica una signatura digital

Generar	**1) Es calcula el HASH del document (SHA-256). 2) El hash es xifra amb la clau PRIVADA del signant: el resultat és la signatura.**
Verificar	1) El receptor desxifra la signatura amb la clau PÚBLICA del signant. 2) Calcula un nou hash del document rebut. 3) Si tots dos hash coincideixen, el document és autèntic i íntegre.

Tres garanties: Autenticitat (l'emissor és qui diu ser, només ell té la clau privada), Integritat (qualsevol canvi al document canvia el hash) i Vinculació/no-repudi (el signant no pot negar haver signat).

EL REPTE DE LA IDENTITAT

Com sabem que una clau pública és de qui diu ser?

- Tenir un parell de claus vàlides no és suficient: com podem garantir que la clau pública que rebem és realment del propietari, i no d'un impostor?
- Dues estratègies: sistemes basats en la confiança (com PGP/OpenPGP: els usuaris es validen mútuament les claus, creant una "xarxa de confiança") i certificats digitals (una entitat de confiança certifica la identitat).

LA SOLUCIÓ MAJORITÀRIA

Certificats digitals i el format X.509

- Els certificats (format més habitual: X.509) es basen en un parell de claus, on una entitat certificadora (CA) signa la clau pública de l'usuari o domini per donar-li validesa.
- Un certificat X.509 conté: la clau pública, la identitat del titular, un número de sèrie, la data de caducitat, i la informació de l'entitat emissora — tot signat digitalment per la CA.



Certificats autosignats: en entorns privats (servidors interns, proves), és habitual generar un certificat on el mateix emissor (issuer) i el subjecte (subject) coincideixen — el veurem a la pràctica.

CONFIAR SENSE CONÈIXER-SE

Trusted Third Party (TTP) i autoritats de certificació



Una TTP és una entitat independent i neutral, reconeguda per totes les parts, que dona fe que una clau pública pertany realment a una persona, empresa o servidor concret. Igual que confiem en un DNI perquè confiem en l'organisme que l'emet, confiem en un certificat perquè confiem en la CA que l'ha signat.

- L'Entitat de Certificació (CA) valida la identitat, emet i signa certificats, i gestiona la revocació dels que ja no són vàlids.
- Model jeràrquic: CA Arrel (Root CA, molt protegida, instal·lada de fàbrica als SO/navegadors) → CA Intermèdia (emet els certificats finals) → Certificat de domini/servidor/usuari.

PKI

Infraestructura de clau pública

Component	Funció
CA	Emet, signa i revoca certificats digitals ("notari digital").
RA (Autoritat de Registre)	Verifica la identitat del sol·licitant abans que la CA emeti el certificat.
VA (Autoritat de Validació)	Comprova en temps real si un certificat és vàlid o revocat (protocol OCSP).
TSA	Certifica la data i hora exactes d'una transacció o signatura.

Quan la confiança falla

- DigiNotar (2011): una CA reconeguda va ser atacada, i l'atacant hi va poder emetre certificats falsos per a Google i altres dominis. La CA va acabar en fallida.
- Atacs homogràfics: registrar dominis amb caràcters visualment similars (per exemple, lletres Unicode) per enganyar l'usuari amb un certificat "vàlid" d'un domini fals.



Precaucions bàsiques: no compartir mai la clau privada; comprovar sempre el domini i la validesa del certificat; no fer clic en enllaços sospitosos rebuts per correu o SMS.

PRÀCTICA REAL

Generant un certificat X.509 amb OpenSSL

- Amb OpenSSL es pot generar, en una sola ordre, una clau privada i un certificat X.509 autosignat.

"openssl req -x509 -newkey rsa:3072 -keyout priv.pem -out cert.pem -days 365 -nodes -subj '/C=ES/O=Puig Castellar Tech SL/CN=intranet.puigcastellartech.local'" genera la clau i el certificat en un sol pas. "openssl x509 -in cert.pem -noout -subject -issuer -dates -fingerprint -sha256" en mostra les dades clau: en un certificat autosignat, el subject i l'issuer coincideixen. Ho practicareu a l'exercici guiat.

MARC LEGAL (UE)

Els tres nivells de la signatura electrònica (eIDAS)

Nivell	Característiques
Simple	Validesa jurídica molt limitada; fàcil d'impugnar. Ex: nom al final d'un correu, casella "Accepto".
Avançada	Identificació única, control exclusiu i integritat garantida. Ex: signar un contracte amb codi SMS de confirmació.
Qualificada	Equivalència legal directa a la signatura manuscrita. Requereix certificat qualificat (FNMT, idCAT, DNIe) i dispositiu segur (QSCD).

PER ACABAR

Idees clau d'avui



Tecnologia vs. llei

Signatura digital (criptografia) i signatura electrònica (validesa legal) són conceptes diferents, sovint complementaris.



Certificats i CA

Resolen el problema de confiar en una clau pública desconeguda, mitjançant una jerarquia d'entitats de confiança.



Tres nivells eIDAS

Simple, avançada i qualificada: cada tràmit exigeix un nivell diferent de validesa jurídica.

ARA ÉS EL TORN VOSTRE



Una empresa vol digitalitzar la signatura dels contractes laborals dels nous empleats.

En parelles: decidiu quin dels tres nivells de signatura electrònica (simple, avançada o qualificada) recomanaríeu per a aquest cas, justificant la resposta, i expliqueu quin mecanisme tècnic concret utilitzaríeu per implementar-la.

10 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF5-AA3: Signatura Digital

Repositori "Materials" (GitHub, SMX-0226SI) · Carlos Alonso Martínez, Escola Pia de Mataró · Llicència CC-BY-SA-4.0

Signicat — Electronic signature: what is it and how to use it

signicat.com/blog/electronic-signature-what-is-it-and-how-to-use-it

Reglament eIDAS (UE) 910/2014

eur-lex.europa.eu

OpenSSL — Generate a CSR / certificat

phoenixnap.com/kb/generate-openssl-certificate-signing-request

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró